

RHEL + Podman standards v0.1

RHEL + Podman standards v0.1 (banking baseline)

SOW item 2 — RHEL standards & best practices. **Prescriptive defaults** for this client. Client platform approves and implements. Contract: SOW.md; discovery alignment: CHARTER-ADDENDUM.md. **Broader platform standards (access, DR, naming, gates):** BANKING-PLATFORM-STANDARDS-v1.md. **Industry authorities (CIS, NIST, FFIEC, Azure, Red Hat):** INDUSTRY-REFERENCES.md.

1. Architecture

Rule	Standard
VMs per env	Two: GitHub runner + Podman runtime
Golden image	Layer 1 SIG — OS only; no app workloads
Deploy	Layer 2 cloud-init/Ansible; Layer 3 GitHub Actions
Container runtime	Podman only — no Docker
Registry	ACR Premium (<code>acr-baseline</code> module) — UAMI <code>AcrPush</code> / <code>AcrPull</code> , private endpoint, quarantine
Image build	Runner only — <code>build/images.manifest.json</code> + <code>build-push-images.sh</code> → ACR

2. Identity (IAM)

Rule	Standard
Human access	Entra ID SSH or per-user accounts — no shared admin
Developer az CLI	PIM eligible roles on dev sub only → scripts/az-developer-login.sh ; see DEVELOPER-AZURE-CLI-ACCESS.md
VM auth	One UAMI per VM — never shared across runner/runtime
Runner UAMI	AcrPush , Key Vault Secrets User
Runtime UAMI	AcrPull , Key Vault Secrets User only
Secrets	Key Vault — no secrets in git, env files on disk, or golden image
Azure CLI on UAT/prod VM	az login --identity -u <uami-id> only
Azure CLI on dev (human)	PIM activate → az-login-developer.sh — not UAMI

3. Network (NSGs)

Rule	Standard
NSG per VM role	nsg-baseline module — deny all inbound default
SSH inbound	Bastion subnet CIDR only
Runtime inbound	APIM subnet (or internal consumers) only
Public IP	Denied (Azure Policy sample provided)
Private IP	Static — document in firewall allow-list
Egress	Hub firewall allow-list — see EGRESS-ALLOW-LIST.md

4. Storage

Rule	Standard
Runtime data	Premium managed data disk — UUID in <code>fstab</code> via <code>mount-data-disk.sh</code>
Podman graph	On data disk (<code>/var/lib/containers</code>)
Shared files	Azure Files NFS optional — UAMI RBAC, private endpoint
Encryption	SSE default; CMK if policy requires

5. OS hardening (Layer 1)

OS baseline (single primary standard)

Rule	Standard
Primary baseline	CIS RHEL 9 Level 1 — OpenSCAP remediate + verify in AIB; evidence in <code>/opt/compliance/artifacts/</code>
DISA STIG	Not default. Use only if GRC mandates — assess with OpenSCAP STIG profile in non-prod ; expect Podman/app compatibility testing and exception process
Do not stack	CIS L1 + STIG on same image without GRC approval — overlapping controls, higher break risk, duplicate remediation
Compliance mapping	Map CIS controls to FFIEC / NIST 800-53 via COMPLIANCE.md — consultant informational only; GRC attests

GRC decision (client records): ☐ CIS L1 sufficient ☐ *STIG required for these hosts*

Technical controls

Control	Implementation
Trusted Launch	Secure Boot + vTPM
SELinux	Enforcing
SSH	No root, no passwords
auditd	Enabled — identity, sudo, execve, Podman paths; audisp → rsyslog
journald / rsyslog	Capped persistent journal; imjournal rate limits; daily logrotate + /var/log/archive retention
Log archiving	90-day rotated logs; 365-day archive; audit-forward log for SIEM path
Patching	dnf-automatic (security only, reboot never); monthly dnf update --security window for validation

Vulnerability assessment gates (OS / VM layer)

Gate	Rule	Owner
Dev	Remediate P0 findings from pen test / Arctic Wolf / continuous scan on Linux before UAT template or SIG promotion	Client security
UAT	No UAT Linux build from golden image while open P0 on OS hardening, SSH, or shared-admin issues	Client platform
Prod	Re-scan or security sign-off before first prod Linux cutover	Client security (Kirk)
Consultant	Advise prioritization and map findings to this standards doc — does not execute pen test or remediate	Vaco

6. CI/CD (Layer 3)

Rule	Standard
CI platform	GitHub Actions self-hosted runner
Build	On runner VM only
Runtime	Pull-only — no <code>podman build</code> on UAT/prod
Ingress	nginx reverse-proxy sidecar — sole published port; app containers internal only — decision: INGRESS-DECISION-NGINX-SIDECAR.md
Workload units	Quadlet (<code>.container</code> , <code>.network</code>) under <code>/etc/containers/systemd/</code>
Reference stack	Gorobi, ingestion, FastAPI APIs, Dagster + nginx — RUNTIME-WORKLOAD-EXAMPLE.md
Promote	GitHub Environments with required reviewers for prod
Reference workflow	<code>.github/workflows/build-deploy.yml</code> , <code>build-images.yml</code>
Build layer doc	BUILD-LAYER.md

7. Monitoring & security

Item	Owner	Implementation
Azure Monitor	Client platform (SIEM path)	Layer 1: rsyslog + AMA prereqs in golden image (<code>azure_monitor.yml</code>). Layer 2: <code>monitor-baseline</code> Terraform module — DCR (syslog auth/daemon/kern + perf counters) → Log Analytics, <code>AzureMonitorLinuxAgent</code> extension, UAMI <code>Monitoring Metrics Publisher</code> on DCR
Logic Monitor	Client (Patrick)	Separate from Azure Monitor — layer-2 bootstrap script on image (<code>enable-logicmonitor-collector.sh</code>)
EDR	Client SOC	Install via approved Ansible when vendor ready
Pen test / vuln scan	Client security	Arctic Wolf, annual pen test, or equivalent — see §5 gates; consultant advises priority only
STIG (if mandated)	Client GRC + platform	Separate assessment track — not combined with CIS L1 without approval

Coexistence: Azure Monitor feeds the bank Log Analytics / Sentinel path; Logic Monitor remains the Patrick-owned operational dashboard. Both agents may run on the same VM.

Layer 1 golden image does not store: workspace keys, DCR IDs, or AMA association — those are Layer 2 Terraform only.

Industry references

Full authority map: INDUSTRY-REFERENCES.md

Section	Primary sources
§1 Architecture	Azure CAF Landing Zone · NIST SP 800-190
§2 Identity	Entra managed identities · Entra SSH for Linux · PIM
§3 Network	NSG overview · MCSB network controls
§4 Storage	Azure managed disks · Azure Files NFS
§5 OS hardening	CIS RHEL 9 Benchmark · OpenSCAP · RHEL 9 Security Hardening · DISA STIGs
§6 CI/CD	Podman Quadlet · GitHub self-hosted runners · GitHub Environments
§7 Monitoring	Azure Monitor Agent · DCR overview